

EHU/UPV

INGENIERITZA INFORMATIKOA

---

**CVE-2021-4034**

---

*Egilea:*  
Iker Sandoval

2025/04/01

## Aurkibidea

|                   |                                     |                   |
|-------------------|-------------------------------------|-------------------|
| <a href="#">1</a> | <a href="#">Sarrera</a>             | <a href="#">3</a> |
| <a href="#">2</a> | <a href="#">Herramientak</a>        | <a href="#">3</a> |
| <a href="#">3</a> | <a href="#">Analisia.</a>           | <a href="#">3</a> |
| <a href="#">4</a> | <a href="#">Erasoa</a>              | <a href="#">3</a> |
| <a href="#">5</a> | <a href="#">Soluzioa</a>            | <a href="#">4</a> |
| <a href="#">6</a> | <a href="#">Ondorioak</a>           | <a href="#">4</a> |
| <a href="#">7</a> | <a href="#">Github repositorioa</a> | <a href="#">4</a> |

# 1 Sarrera

Informatika-segurtasunaren arloan, ahultasunak ustiatzea ezinbesteko praktika da sistemak nola konprometitzen diren eta, azken finean, nola babestu ikasteko. Sistema zaharretan edo behar bezala konfiguratu gabe daudenean. Kasu honetan ikusiko dugu 2021-ean aurkitu zen vulnerabilitate betegaz, ezagutzen dena PwnKit bezala. Kasu honetan, pkexec zerbitzuaren bitartez egiten zen. SUID bitaren bitartez root shell bat lortzea.

Honen helburua izango da ikustea nola exekutagarri bat izanda eta 2021-eko konfigurazioak izanda, ikustea nola posible den root bezala jartzea.

## 2 Herramientak

- Linux bat
- pkexec

## 3 Analisia.

pkexec exekutatzeke hainbat argumentu erabili ahal dira. Programak ez du konprobatzen pakete kopurua, hau kontuan izanda guk nahi dugun argumentuaren posizioan sar dezakegu informazioa.

Hasteko, jakin behar dugu parametroak pasatzen ditugunean, parametro hauek erregistroetan gordetzen direla eta lehengo seiak pilan gordeko dira orden honetan: 1. RDI 2. RSI 3. RDX 4. RCX 5. R8 6. R9

7. argumentua out-of-bounds read sortuko du, momentu honetan envp[0] begira egongo da. envp ingurunearen lehenengo aldagaia da.

632. lerroan g\_find\_program\_in\_path(path) funtzioarekin deia egingo dio envp[0] duen balioarekin zeren eta ez da hasten slash batekin. Honek balio hori duen exekutagarri baten helbidea itzuliko du eta 639. lerroan idatziko da envp[0] erregistroan balorearen helbidearekin.

## 4 Eraso

Erasoa egiteko saiakera gutxi ditugu zeren eta 702. lerroan bere ingurunea ezabatzen du.

pkexec errore bat printeatzeke GLib's g\_printerr() funtzioa erabiltzen du. Adibidez: validate\_environment\_variable(), log\_message() eta call g\_printerr().

Funtzio honek UTF-8 erabiltzen du printeatzeke baino ezin ditu printeatu ingurunearen CHARSET aldagaia UTF-8 ez badago eta horretarako g\_printerr() funtzioak iconv\_open() funtzioa deituko du. Liburutegi honek aldaketa egiteko GCONV\_PATH aldagaia erabiltzen du, aldagai honek ahalbidetzen du beste konfigurazio fitxategiak irakurtzea.

Nola ez denez seguroa, ld.so SUID ingurunearen programetarik ezabatzen du. Baina gure asmoa izango da liburutegi pertsonal bat exekutatzea eta honekin lor dezakegu root bezala egitea.

Jakin behar dugu, eraso honek log erregistroetan azarnak uzten dituela. Bertan ikus dezakegu, idatzitako gauzak.

Web orrialde originala:

- <https://www.qualys.com/2022/01/25/cve-2021-4034/pwnkit.txt>

GitHub erabilia

- <https://github.com/berdav/CVE-2021-4034.git>
- <https://github.com/Y3A/CVE-2021-4034.git>

Oinarri bezala hartuko ditugu.

Hasi gara lehengo .c batekin (pwkit.c). Bertan, setuid eta setgid 0 bezala esleituko dira eta bi array sortuko ditugu bata sistemaren \$PATH-arekin, horretarako erabili dezakezu echo \$PATH eta bestea shell-aren helbidearekin”.

Bigarren .c-arekin (cve-2021-4034) ingurune baten simulazioa sortuko dugu array batean.

- sortuko dugun liburutegi maltzuraren izena: izena.so.
- PATH=GCONV\_PATH=.
- "SHELL= eta existitzen ez den ruta bat",
- "CHARSET=PWNKIT",
- "GIO\_USE\_VFS=",
- NULL

glibc karaktereak erabilita GCONV\_PATH eta gconv-modules erabilita liburutegi maltxur bat sortuko dugu .so extensioarekin

eta makefile bat non TRUE=\$ shell helbidea jarriko du, .so liburutegia sortuko du, gconv-modules eta GCONV\_PATH fitxategiak sotuko ditu eta cve-2021-4034 exekutatu du.

## 5 Soluzioa

Soluzio erraz bat da SUID bita desaktibatzea chmod 0755 bitartez. Lehenengo zenbakia SUID-ri erreferentzia egiten dio eta 0 izanda hau desktibatzen du. Hurrengoak baimen arruntak dira: owner,group eta others.

## 6 Ondorioak

Praktika honek erakutsi digu nola funtzionatzen duten zero day motako ahuleziek linux inguruneetan eta nola manipulatu programak kalteberak kontrolatzeko. Gainera, SUID bitarekin eskubideak igotzeak sistema eragileetan pribilegioen kudeaketa oso garrantzitzua dela.

Ustiapenaren arrakasta eraso egituratu batean. Gainera, inguruneko babes-neurriak gaitasungabetzeak ahultasuna errepikatzeko proba kontrolatuak egitea ahalbidetu du.

Praktikaren bidez ikasitakoak sistema errealean ahuleziak identifikatzeko eta horiei aurre egiteko balioko du, baita programazio-praktika seguruak aplikatzeko ere. Babes-neurriak ezartzea eta pribilegioak behar bezala kudeatzea oinarritzko urratsak dira sistema seguruak izateko.

## 7 Github repositorioa

<https://github.com/ikerSandoval003/CVE-2021-4034.git>